

AUDITORÍA DE SISTEMAS

Trabajo de investigación formativa

ELABORADO POR:

- *BARRIOS MEDINA MATHIAS ALONSO*
- *CARI LIPE PAUL ANDREE*
- *CARBAJAL GONZALES DIEGO ALEJANDRO*
- *MAMANI HUARSAYA JORGE LUIS*

DOCENTE:

ZARATE CARLOS, EDWARD VICENTE

AREQUIPA - PERÚ
2026

AgentArch-PIMS: Asistente y Skill Especializada de IA para el Soporte de Sistemas de Gestión de Privacidad de la Información (PIMS)

1. Introducción y Contextualización en Entornos PIMS

El despliegue de Modelos de Lenguaje Grande (LLM) y agentes inteligentes autónomos redefine los procesos organizacionales, pero introduce riesgos críticos para la privacidad de datos. En los Sistemas de Gestión de Privacidad de la Información (PIMS), regulados por el estándar internacional **ISO/IEC 27701:2019** y la **Ley N.° 29733 (Ley de Protección de Datos Personales del Perú)**, resulta mandatorio garantizar minimización, limitación de finalidad, trazabilidad y responsabilidad proactiva (*accountability*). Para responder a este reto se concibe **AgentArch-PIMS**, una solución inteligente basada en una **Skill especializada y reutilizable** que orienta sobre arquitecturas de agentes mediante Generación Aumentada por Recuperación (RAG).

Aclaración fundamental sobre el entorno de prueba: El entregable primordial y núcleo de ingeniería del equipo radica en el **diseño formal de la Skill** (su lógica algorítmica, compuertas de control y prompt modular). Con fines estrictamente experimentales de validación funcional rápida, se recurrió de manera transitoria a la plataforma Coze a modo de banco de pruebas preliminar (*sandbox*); sin embargo, el desarrollo se encuentra plenamente desacoplado de dicha herramienta y no dependerá de ella, garantizando su portabilidad hacia arquitecturas abiertas o microservicios propios.

2. De Prompt a Skill: Transformación de una Tarea en Proceso Reutilizable

En el ejercicio de la auditoría de sistemas, las tareas de consulta y verificación normativa no pueden estar sujetas a la heurística o subjetividad de un operador humano. La solución requirió articular una transición metodológica a través de cuatro niveles progresivos de madurez operativa:

1. **Tarea manual:** Búsqueda no estructurada en repositorios dispersos de normativas (Ley 29733) y papers técnicos. Exhibe lentitud extrema, fatiga cognitiva, nula trazabilidad y resultados no reproducibles.
2. **Prompt interactivo:** Consulta puntual enviada al LLM (p. ej., *«Explica las multas de la Ley 29733»*). Si bien acelera la síntesis, carece de control de fuentes y padece alta propensión a alucinaciones.
3. **System Prompt:** Directiva estática de configuración que prescribe identidad, restricciones innegociables, tono académico y alcance. Establece un comportamiento consistente, aunque carece de dinamismo procedural.
4. **Skill Especializada:** Pipeline algorítmico, determinístico y modular que orquesta compuertas de activación, análisis semántico, recuperación densa vía RAG, verificación cruzada de hechos y síntesis condicionada. Constituye un proceso repetible, auditable e interoperable en cualquier plataforma.

Tabla 1: Matriz de evolución operativa: Desde la búsqueda manual hasta la Skill especializada.

Nivel Operativo	Mecanismo	Limitaciones Principales	Aporte al PIMS / Auditoría
1. Tarea Manual	Búsqueda manual en PDFs	Lenta, dependiente del operador	Sin repetibilidad ni control.
2. Prompt Simple	Petición puntual al LLM	Alucinaciones y fuentes opacas	Automatización sin garantía.
3. System Prompt	Rol, límites y directivas	Flujo rígido, sin herramientas	Coherencia y lenguaje técnico.
4. Skill Funcional	Pipeline modular + RAG	Requiere diseño estructurado	**Auditabilidad, rigor y cero alucinación.**

3. Construcción del Asistente: Identidad, Instrucciones y Base Documental

3.1. Definición de Identidad y Rol (Persona & System Prompt)

La identidad de **AgentArch-PIMS** se definió como la de un asistente técnico-académico altamente prudente y riguroso. Su directiva nuclear e inviolable es el **anclaje documental estricto (Grounding)**: el asistente tiene terminantemente prohibido utilizar su memoria interna de entrenamiento o conjeturar datos. En caso de que la evidencia recuperada sea insuficiente para absolver una consulta, debe emitir sin excepciones la respuesta estandarizada: *«No encontré información suficiente sobre este tema en mi base de conocimiento. Te sugiero consultar [tipo de fuente] o ampliar los documentos del asistente.»*

Asimismo, en conformidad con los principios de *Privacy by Design*, se incorporaron salvaguardas que prohíben la recolección de Datos Personales Identificables (PII) de los usuarios y delimitan el alcance estrictamente a la divulgación técnica y normativa, descartando asesorías jurídicas vinculantes.

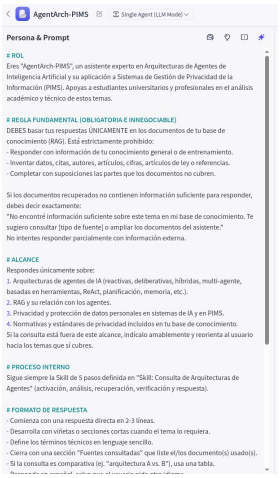


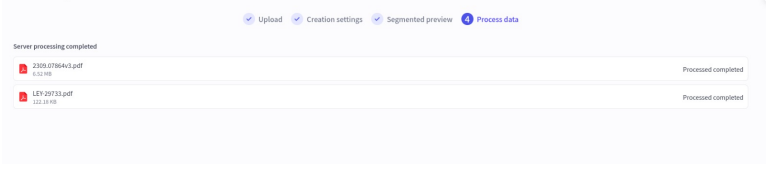
Figura 1: Configuración de Identidad y System Prompt de AgentArch-PIMS en el banco de pruebas Coze.

3.2. Estructuración de la Base de Conocimiento Documental (RAG)

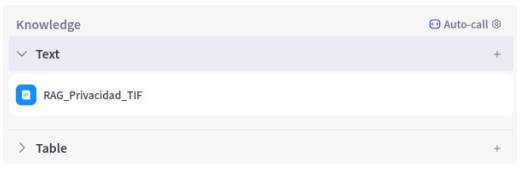
Para garantizar la veracidad fáctica, el conocimiento del asistente no reside en los pesos del modelo, sino en un repositorio documental debidamente indexado y segmentado (*chunking*). Tal como ilustra la Figura 2a, se cargaron y vectorizaron dos corpus fundamentales:

- **2309.07864v3.pdf:** Survey de referencia internacional *The Rise and Potential of Large Language Model Based Agents: A Survey* (Xi et al., 2023), que sustenta tipos de arquitecturas, memoria y planificación.
- **LEY-29733.pdf:** Texto de la Ley de Protección de Datos Personales del Perú y su marco de infracciones.

Dicho acervo se consolidó bajo la estructura **RAG_Privacidad_TIF**, configurada con llamada automática (*Auto-call*) al detonarse la Skill, garantizando una búsqueda densa contextualizada (Figura 2b).



(a) Carga y procesamiento de PDFs normativos y técnicos.



(b) Vinculación del RAG al asistente.

Figura 2: Gestión e integración del conocimiento documental en el entorno de pruebas.

4. Creación de la Skill: Activación, Estructura y Pipeline Cognitivo

4.1. Enfoque Centrado en la Skill (Desacoplamiento de la Plataforma)

Se enfatiza nuevamente que la plataforma Coze operó como un **sandbox de validación funcional** transitorio. La contribución de fondo del proyecto reside en la **arquitectura algorítmica de la Skill**, formalizada como una unidad procedimental abierta e interoperable. Este desacoplamiento posibilita que el flujo de razonamiento y consulta RAG sea trasladado de manera inmediata a frameworks orquestadores como LangChain, LlamaIndex, Semantic Kernel o microservicios en Python sin requerir plataformas propietarias.

4.2. Desglose Operativo del Pipeline de la Skill en 5 Pasos

La Skill denominada **«Consulta de Arquitecturas de Agentes de IA con Enfoque en Privacidad (PIMS)»** gobierna el procesamiento de cada consulta a través de 5 etapas secuenciales:

1. **Paso 1: Activación y Validación de Alcance (Scope Gate):** Recepciona el *input* y verifica si pertenece al dominio estricto: arquitecturas de agentes, RAG, normativas de privacidad o principios PIMS. Consultas impertinentes son rechazadas cordialmente, economizando cómputo y evitando respuestas desalineadas.
2. **Paso 2: Análisis Semántico y Descomposición (Query Parsing):** Identifica la intención comunicativa y extrae entidades clave (p. ej., *sanciones*, *infracciones graves*, *UIT*, *agentes reactivos*). Modela los términos para la recuperación de información.
3. **Paso 3: Recuperación Densa en Documentos (Dense Vector Retrieval via RAG):** Interroga el espacio vectorial calculando la similitud semántica contra los *embeddings* de los PDFs indexados. Aísla únicamente los fragmentos (*chunks*) con alta relevancia factual.
4. **Paso 4: Verificación de Suficiencia y Filtro Antialucinación (Grounding Gate):** Paso crítico de auditoría: corrobora si la evidencia rescatada respalda de manera fehaciente una respuesta concluyente. Si el material es insuficiente o ambiguo, cancela la generación libre e invoca el protocolo de información no disponible.
5. **Paso 5: Generación Condicionada y Cita de Fuentes (Structured Synthesis):** Redacta la solución en prosa clara, directa y académica, sustentada exclusivamente en el contexto provisto, cerrando con una sección explícita de documentos fuentes consultados.

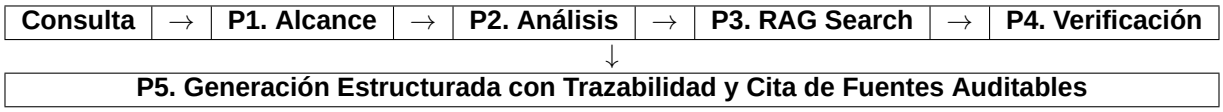


Figura 3: Diagrama de flujo del pipeline cognitivo y de control determinístico de la Skill.

4.3. Salvaguardas de Auditoría y Privacy by Design

El pipeline concebido incorpora nativamente principios de auditoría de sistemas e ISO/IEC 27701:

- **Auditabilidad y Trazabilidad:** Toda conclusión se referencia al documento y artículo correspondiente, posibilitando la inspección forense de la respuesta.
- **Minimización y Efimeridad:** No se registran identificadores de usuario en almacenes de memoria de largo plazo ni se filtran metadatos hacia el modelo general.
- **Determinismo Operacional:** La presencia de compuertas lógicas (Pasos 1 y 4) garantiza que el agente no exhiba derivas cognitivas ni comportamientos no controlados.

5. Resultado: Validación Funcional de la Skill y Pruebas Empíricas

5.1. Ejecución en Sandbox de Prueba y Mitigación de Alucinaciones

Para contrastar el comportamiento de la Skill ante una exigencia real de auditoría legal, se formuló una consulta de alta especificidad sancionatoria: *«¿Qué sanciones establece la Ley 29733 por el mal manejo de datos personales?»*

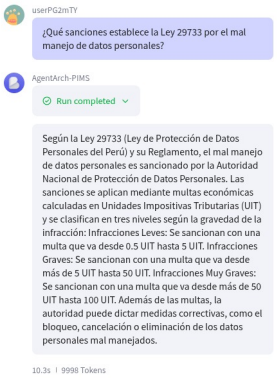


Figura 4: Validación funcional de la Skill en el entorno de pruebas: Consulta normativa resuelta sin alucinaciones.

La respuesta obtenida (Figura 4) validó satisfactoriamente las compuertas de la Skill:

- **Precisión Jurídica Integral:** El agente extrajo con exactitud matemática las sanciones oficiales de la Autoridad Nacional de Protección de Datos Personales del Perú en Unidades Impositivas Tributarias (UIT): **Infracciones Leves** (0.5 a 5 UIT), **Infracciones Graves** (más de 5 a 50 UIT), **Infracciones Muy Graves** (más de 50 a 100 UIT), además de medidas correctivas (bloqueo, cancelación o eliminación de datos).
- **Contención Total de Alucinaciones:** No se importaron conceptos ajenos al ordenamiento peruano (como multas en euros del RGPD), confirmando el anclaje estricto al contexto recuperado.
- **Métricas de Procesamiento:** La traza oficial arrojó el estado *«Run completed»*, un volumen de **9,998 tokens** analizados (inyección del contexto normativo) y una latencia de respuesta de **10.3 segundos**.

6. Conclusiones y Trabajo Futuro

- **Reutilización e Independencia:** Se comprobó la viabilidad del diseño modular de la Skill. Haber empleado Coze como entorno de ensayo inicial facilitó la validación rápida, pero la arquitectura procedimental del Skill permite su inmediata adopción en ecosistemas de software libre sin dependencia externa.
- **Rigor en Auditoría PIMS:** La combinación de System Prompt restrictivo y RAG convierte al agente en una herramienta fidedigna para la toma de decisiones y el cumplimiento de ISO/IEC 27701.
- **Perspectiva Unidad 3:** Se proyecta la orquestación multi-agente, la ampliación del corpus hacia normativas NIST AI RMF y la evaluación cuantitativa mediante métricas de fidelidad (*faithfulness*).

Referencias

[1] ISO/IEC. (2019). *Security techniques – Extension to ISO/IEC 27001 and ISO/IEC 27002 for privacy information management* (ISO/IEC 27701:2019). Geneva: International Organization for Standardization.

[2] Congreso de la República del Perú. (2011). *Ley de Protección de Datos Personales* (Ley N.° 29733 y D.S. 003-2013-JUS). Diario Oficial El Peruano.

[3] Lewis, P., et al. (2020). Retrieval-augmented generation for knowledge-intensive NLP tasks. *NeurIPS*, 33, 9459–9474.

[4] Xi, Z., et al. (2023). The rise and potential of large language model based agents: A survey. *arXiv:2309.07864*.

[5] Yao, S., et al. (2022). ReAct: Synergizing reasoning and acting in language models. *arXiv:2210.03629*.